

SIH26231 — Digital Companion for Field Drug Testing

Implementation Plan: Tech Stack, Architecture, Backend, Security & Permissions

Team: 5 members (2 Research, 2 Build, 1 Editor/PPT, 1 PM/Domain Expert) **Budget:** ₹0 — every component below is free-tier, open-source, or built into the OS **Design goal:** Nation-level worthy engineering, honestly scoped for a student team's build window

1. Guiding Principle

Every choice below follows three rules, carried over from the design discussion:

1. **Deterministic before ML** — the core Positive/Negative/Inconclusive decision must be explainable in a courtroom, not just a demo.
 2. **Fail closed** — any uncertainty (bad image, no GPS, clock mismatch, missing signature) degrades to "flagged/inconclusive," never to a silent wrong answer.
 3. **Zero paid dependency** — nothing in this stack requires a credit card, ever. Where a "free tier" has a catch (rate limits, auto-pause), it's called out explicitly so it doesn't surprise you during judging.
-

2. Tech Stack (all free)

Layer	Choice	Why	Cost
Mobile app framework	Flutter (Dart)	Single codebase for Android+iOS, strong camera control, easy platform-channel access to Android Keystore / iOS Secure Enclave	Free, open-source
Camera capture	<code>camera</code> Flutter plugin	Direct frame access needed for burst capture + live quality checks	Free
Computer vision	OpenCV (via <code>opencv_dart</code>) or native Android/iOS OpenCV SDK through platform channel)	Reference-card detection, blur (Laplacian variance), color-space conversion (RGB→Lab)	Free, open-source (Apache 2.0)
Card corner detection	OpenCV ArUco markers	Print 4 small ArUco markers at the corners of your reference card — far more robust to rotation/tilt than plain edge detection	Free
QR/barcode scan (card serial, officer ID badge)	Google ML Kit — Barcode Scanning API	Fully on-device , works offline, no API key, no internet call	Free, unlimited
Local database	SQLite via <code>sqflite</code> , encrypted with SQLCipher	Embedded, works fully offline, supports your hash-chain ledger as a normal table	Free, open-source
Local secret storage	<code>flutter_secure_storage</code> (wraps Android Keystore / iOS Keychain)	Stores wrapped keys, never raw key material	Free

Layer	Choice	Why	Cost
Hashing	SHA-256 via Dart's built-in <code>crypto</code> package	Standard, matches BSA Section 63's expected algorithm	Free
Device signing key	Android Keystore (StrongBox where available) / iOS Secure Enclave , ECDSA P-256	Hardware-backed, non-exportable — this is what makes "signed by this device" meaningful	Free (OS-native)
Officer-bound key	PBKDF2/Argon2 key derivation from officer PIN + salt, via Pointycastle (Dart crypto library)	Second signing factor, independent of the device	Free, open-source
Backend / DB	Firebase Spark (free plan) — Firestore + Cloud Storage + Cloud Functions + Auth	Always-on (doesn't sleep/pause like some free tiers), generous free quota, good offline-sync SDKs	Free
Alternative backend	Supabase free tier (Postgres, if your team prefers SQL for search/audit queries)	Real relational DB, row-level security	Free — <i>but auto-pauses after 7 days of inactivity; ping it with a free UptimeRobot monitor before demo day</i>
Extra server logic (Merkle root batching, certificate generation)	Render.com free web service (Node/Express) or Firebase Cloud Functions	Free compute for backend jobs	Free — <i>Render free tier sleeps after 15 min idle, ~30–50s cold start on first request; same UptimeRobot trick fixes this before a demo</i>
SMS out-of-band anchor	Native device SMS (Android <code>SmsManager</code> via <code>telephony</code> / <code>flutter_sms</code> plugin)	Sends through the officer's own SIM — no third-party SMS gateway or API key needed at all	Free (beyond normal telecom SMS, usually already covered on govt-issued SIMs)

Layer	Choice	Why	Cost
GPS	<code>geolocator</code> Flutter plugin	Native device GPS/network location	Free
Reverse geocoding (optional, human-readable location)	OpenStreetMap Nominatim	Free, no key required for low-volume use (respect usage policy, add attribution)	Free
Push notifications	Firebase Cloud Messaging (FCM)	Sync status, supervisor approval alerts	Free, unlimited
Design mockups	Figma free tier	For the Editor/PPT person	Free
Repo + CI	GitHub (apply for GitHub Student Developer Pack — free private repos, free domain credits, free Sentry, extra perks)	Version control, GitHub Actions for CI	Free
Error tracking (optional)	Sentry free tier (comes via Student Pack)	Crash/error monitoring during testing	Free
MDM concept (for the "nation-level" story, not required for demo)	Headwind MDM (open-source)	Shows you've thought about how NCB would actually provision/revoke hundreds of devices	Free, self-hostable

No paid API is required anywhere in this stack. Everything sensitive (signing, hashing, on-device barcode reading) runs on the phone itself using OS-native or open-source capability — this is a deliberate design choice, not just a budget workaround, because it also means less attack surface and no dependency on a third party being trustworthy.

3. System Architecture





4. Module-by-Module Design

4.1 Capture & Calibration Engine (Builder 1)

- **Reference card:** print with 4 ArUco markers at corners + a strip of known-value color/grayscale patches + a unique printed serial + QR code.
- **Live gating:** reject capture (with on-screen reason) if — card not fully in frame, Laplacian blur variance below threshold, exposure clipped, or reaction timer outside the reagent's valid reading window (get exact windows from Researcher A).
- **Burst capture:** 3–5 frames at slight angle variation → pick best frame by ROI variance/least specular highlight; also enables reflection/moiré spoof detection (photo-of-a-photo).
- **Calibration math:**
 1. Detect ArUco corners → locate color/grayscale patches.
 2. Compute white-balance/illumination correction from the grayscale patches.
 3. Apply correction to the reaction-zone pixels.
 4. Convert sRGB → CIE Lab.
 5. Compute ΔE_{2000} distance between corrected reaction color and the reagent's documented reference color.
 6. Threshold (versioned, not hardcoded permanently — see Section 6) → Positive / Negative / Inconclusive.
- **Per-device-model correction profile:** build once against a small reference set of phone models your team can access; apply by device fingerprint at runtime.

4.2 Evidence Record & Hash Chain (Builder 2)

Each record on a device links to the previous record on that same device:

```
record[n].hash = SHA256( record[n].data + record[n-1].hash )
```

This is an **append-only local ledger** — deleting, reordering, or backdating any past record breaks every hash after it, detectable without needing to trust anyone's word.

4.3 Dual-Bound Signature

A record is only valid with **both** signatures present:

Signer	Proves	Lives in
Device key (ECDSA P-256, hardware-backed)	<i>This exact phone</i> captured this image	Android Keystore/StrongBox or iOS Secure Enclave — non-exportable
Officer key (PBKDF2-derived from PIN, per-test)	<i>This specific officer</i> authorized the capture	Derived at time of use, never stored raw

Stolen phone → no officer PIN. Impersonated/coerced officer without the device → no hardware key. Breaking both simultaneously, in the field, without leaving evidence, is a materially higher bar than a single signature.

4.4 SMS Out-of-Band Anchor

The moment a record is chained locally, the app sends a short SMS (just the hash, ~40 characters) to a central NCB-controlled number via the **device's own SIM** — no gateway subscription needed. This works even on pure 2G with no data connectivity, and creates an independent, officer-uncontrollable timestamp witness outside the phone itself.

4.5 Offline-First Sync

- Each device keeps its **own** sub-chain while offline — avoids merge conflicts between officers who were offline in different districts simultaneously.
- On reconnect: metadata+hash sync first (tiny, works on weak signal), full image sync when real bandwidth returns.
- Storage pressure never silently discards unsynced records — it blocks new captures and alerts instead.
- Missing GPS/network → record still created, flagged `location_unconfirmed`, never silently blank.

4.6 Roles & Access Control

Kept deliberately light at capture, strict at the audit/export layer:

Role	Can do
Officer	Capture tests; view/search own records only
Supervisor	Co-sign high-stakes cases; approve bulk exports; view district records
Auditor	Read-only, entire chain including the access log itself; cannot alter anything
Admin	Provisions/revokes devices and reference cards; cannot view case content (separation of duties)

4.7 Leak Traceability

- Every export embeds an **imperceptible, export-specific watermark** (basic LSB or DCT-domain embedding is enough for a working demo) tying a leaked image back to exactly who exported it, when, and why.
- `FLAG_SECURE` (Android) / equivalent iOS API blocks screenshots on sensitive screens.
- Bulk export requires Supervisor sign-off, itself logged in the chain-hashed audit trail.
- Any externally shared copy is redacted-by-default (GPS/officer ID stripped) unless explicitly flagged as a full chain-of-custody legal request.

5. Backend: API & Data Model Sketch

Core tables/collections:

- `devices` — device_id, hardware key fingerprint, assigned officer, status
- `reference_cards` — serial, QR code, issued-to, status
- `tests` (the hash-chain ledger) — test_id, prev_hash, record_hash, officer_id, device_id, kit_type, timestamp, gps + confidence flag, image ref, image hash, ΔE /calibration result, classification, reagent-window-ok flag, card serial used, device signature, officer signature, sync status
- `merkle_roots` — periodic batch roots folding many devices' synced hashes
- `audit_log` — itself hash-chained: actor, action, target, timestamp
- `exports` — requester, approver (if bulk), included test IDs, watermark ID

Key endpoints:

- `POST /sync/records` — upload a batch of chained metadata records
- `POST /sync/media/{test_id}` — upload image after metadata is anchored
- `GET /records?query=` — role-gated search
- `POST /records/{id}/export` — generates BSA §63 certificate + watermarked copy
- `POST /anchor/merkle` — scheduled job folding recent hashes into a Merkle root
- `POST /devices/provision` — Admin-only device/card registration

- `GET /audit` — Auditor-only

6. Security Measures — Threat Map

Attack	Mitigation
Officer edits/deletes a past record	Hash chain breaks — detectable
Phone stolen, used to fabricate a record	Missing officer-PIN signature
Officer coerced into fabricating a record	Reaction timer window + optional second-signer for high-stakes cases
Reused/photocopied reference card	Card serial cross-checked against issuance log
Photo-of-a-photo replay	Burst capture + reflection/moiré detection
GPS spoofing	Cross-check against network-based location; flag mismatch, don't reject silently
Server-side record alteration	Periodic Merkle root, independently anchored (even a simple daily hash-of-hashes to an external log)
Data leak via authorized export	Per-export watermark, screenshot blocking, redact-by-default, bulk-export approval gate
Overclaiming forensic certainty	"Presumptive — lab confirmation required" structurally enforced on every export path, no bypass
Gaming a published fixed threshold	ΔE threshold versioned and periodically recalibrated, not published as a fixed public number (methodology stays open, exact number doesn't)

7. Free APIs/Services — What You Actually Need to Sign Up For

Service	What for	How to get it
Firebase project	Firestore, Storage, Auth, Functions, FCM	console.firebase.google.com → free Spark plan, no card required
Google ML Kit	On-device barcode scanning	Bundled as a Flutter plugin (<code>google_mlkit_barcode_scanning</code>) — no separate account/key needed , works fully offline
GitHub Student Developer Pack	Free repos, CI minutes, domain, Sentry, extra credits	education.github.com/pack — apply with your college email, usually approved within a day
Render.com (optional, if not using Firebase Functions)	Extra backend compute	render.com → free web service tier, connect GitHub repo
Supabase (optional alternative to Firebase)	Postgres-based backend	supabase.com → free tier, remember the 7-day auto-pause caveat
UptimeRobot	Free monitor to ping Render/Supabase and prevent sleep/pause before a demo	uptimerobot.com — free tier, 5-minute interval monitors
OpenStreetMap Nominatim	Free reverse geocoding	No signup for light use — just follow their usage policy (rate limit, add attribution)

That's the entire external-account list. Everything else (OpenCV, SQLCipher, Keystore/Secure Enclave, native SMS) is either bundled into your app or built into the phone's OS.

8. Permissions You'll Need

8.1 Runtime permissions the app requests from the officer's phone

Permission	Why	Notes
<code>CAMERA</code>	Core capture	Mandatory, requested on first launch
<code>ACCESS_FINE_LOCATION</code>	GPS tagging of each test	Foreground only — no background location needed
<code>SEND_SMS</code>	Out-of-band hash anchor	Android runtime permission; explain clearly why it's needed (officers will be wary of an app that silently sends SMS)
<code>POST_NOTIFICATIONS</code> (Android 13+)	Sync status, supervisor approval alerts	Runtime permission
Biometric (<code>USE_BIOMETRIC</code>)	Optional alternative/addition to PIN for officer signing factor	Optional enhancement
Storage	Scoped storage handles this automatically on Android 10+; minimal manual permission needed	

Design note: ask for each permission contextually (right when the feature is first used), not all at once at install — officers are more likely to trust and grant permissions when the reason is immediately obvious.

8.2 Organizational "permissions" — the ones that actually matter for a government pilot

This is different from app permissions, and it's the part most student teams miss:

- **Device provisioning authority:** someone (an Admin role) has to formally issue devices + reference cards to officers, tying hardware keys to real identities. For your SIH demo, you don't need a real provisioning bureaucracy — just show the *flow* (Admin screen: register device → register officer → issue card serial).
- **Data retention & ownership sign-off:** how long does NCB expect records retained, and who owns deletion rights? Align this to the NDPS (Seizure, Storage, Sampling and Disposal) Rules, 2022 timelines — Researcher B should pull the exact retention window so your app's config isn't arbitrary.
- **Legal basis for processing officer + location data:** under India's **Digital Personal Data Protection Act, 2023**, processing necessary for the prevention, detection,

investigation, or prosecution of offences is exempted from most consent-based obligations (Section 17). This means you don't need a consumer-style consent popup from the *accused* — but it's still good practice to give **officers** a clear onboarding screen explaining what's logged about their own activity, since they're the app's actual users. Note: the DPDP Act's implementation has been phased — mention in your deck that your data-handling design follows the Act's intent regardless of exact commencement-phase status, which reads as more careful than either ignoring it or overclaiming compliance.

- **MDM enrollment:** for a real deployment (not needed for SIH demo), a free/open-source MDM like Headwind MDM would be how NCB pushes the app and remotely wipes lost devices at scale — worth one slide, not a build item.

9. Legal/Compliance Mapping (carry this into your deck, it's a genuine differentiator)

Requirement	Law	How your app satisfies it
Photograph as primary evidence	NDPS Act, Section 52A(4) — inventory/photographs, once compliant with procedure, are primary evidence	Capture flow supports presence-of-accused flag, proper inventory format, duplicate sample logging
Electronic record admissibility	Bharatiya Sakshya Adhiniyam 2023, Section 63 — requires hash value + two signatures in a certificate	Auto-generated certificate export with SHA-256 hash + device/officer signatures, matching the official format
Data processing basis	DPDP Act 2023, Section 17	Law-enforcement investigation processing is exempted from most consent obligations; officer-facing transparency still built in as good practice

10. Build Roadmap (mapped to your team, zero-budget realistic)

Phase	Focus	Owners
1	Capture pipeline: camera + ArUco card detection + blur/exposure gating	Builder 1, guided by Researcher A
2	ΔE 2000 calibration engine + Positive/Negative/Inconclusive threshold logic	Builder 1 + Researcher A
3	Local hash chain + SQLCipher storage + dual-signature scheme	Builder 2 + Researcher B
4	Offline queue + staged sync to Firebase	Builder 2
5	SMS anchor + Merkle root batching (server-side)	Builder 2
6	Roles, audit log, export watermarking, BSA-63 certificate generator	Builder 2 + Researcher B
7	End-to-end demo: bad-lighting photo $\rightarrow$ corrected result; sample compliant record end-to-end	Whole team
8	Deck, architecture diagrams, demo video	Editor/PPT, fed by everyone

Build order matters: get Phases 1–2 working first — a live demo of calibration turning a bad-lighting photo into a readable, correct classification is your single strongest stage moment, and it doesn't depend on any backend work at all.

11. Known Limitations (say these out loud in your deck — it builds credibility, not weakness)

- LSB watermarking is fragile to recompression — sufficient for a working demo and for detecting naive leaks, but a determined adversary re-encoding the image can strip it. Say this plainly if asked.
- Supabase's free-tier auto-pause and Render's free-tier cold start are real constraints — mitigate with UptimeRobot pings before your demo slot, and mention Firebase as your always-on primary choice.
- Per-device-model color correction profiles will only be validated against whatever phone models your team can actually get hands on — say this is a "starter set, extensible" rather than claiming universal device coverage.
- The classifier's ΔE threshold is a starting point calibrated from published reagent-color literature, not validated against NCB's actual proprietary reagent batches — be

upfront that real deployment would need NCB's cooperation to calibrate against their exact kits.

This plan complements the security council review, the false-positive-rate research on colorimetric field tests, and the legal grounding (NDPS §52A, BSA §63, DPDP §17) already gathered for this project — combine with those documents for the full picture in your submission.